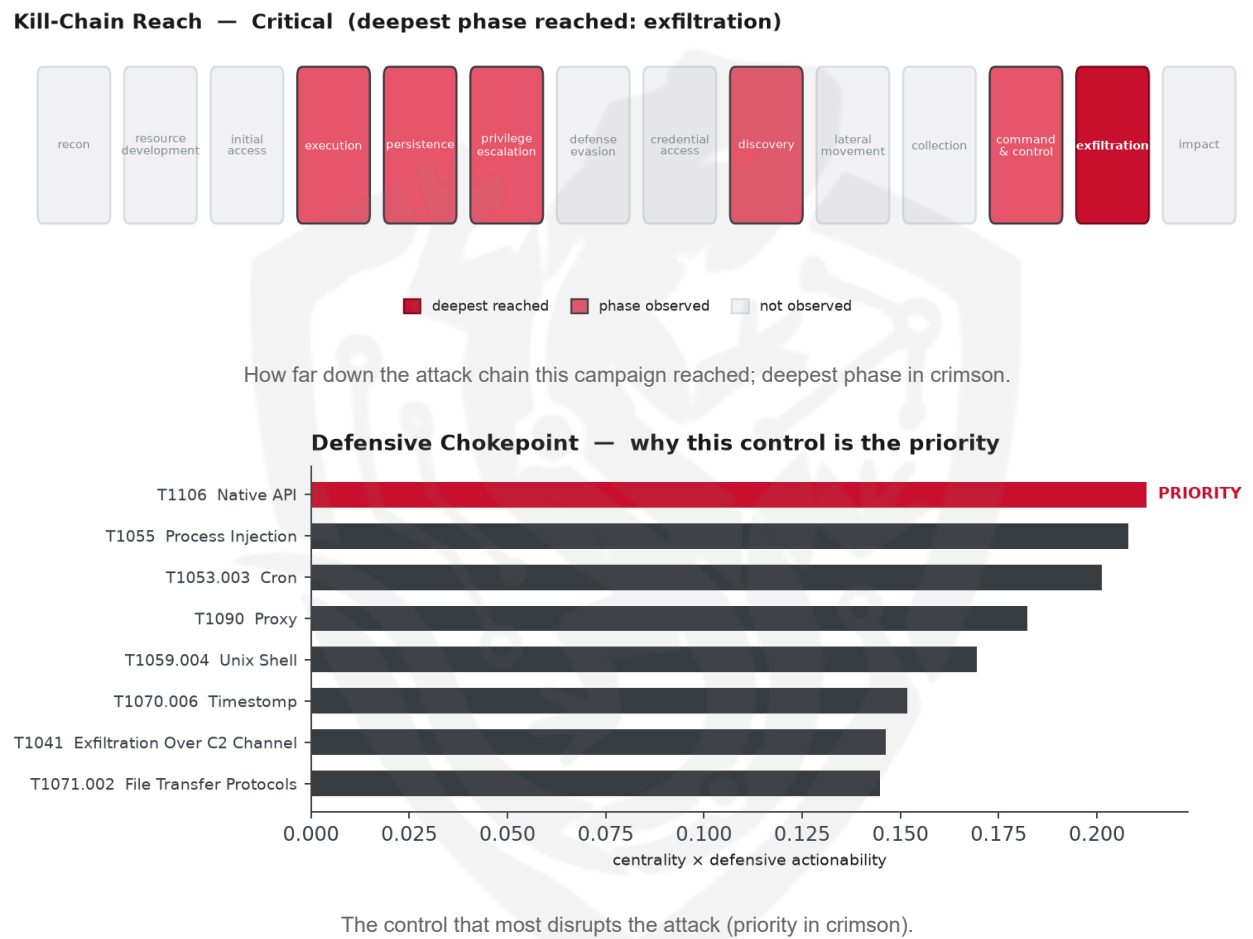


THREAT REPORT: APT41 DEPLOYS MELOFEE LINUX IMPLANT

Visual Summary



Summary

The source attributes this activity to APT41, which has been observed operating a Linux-based implant known as Melofee and related variants. No specific CVE is identified for the exploitation, and the targeted geography and sectors remain unspecified. The campaign leverages a range of techniques, including native API calls that enable persistence and data exfiltration. Priority should be given to enabling EDR API-telemetry and alerting on unusual direct Native API use from non-system processes.

Threat Overview

APT41 is employing the Melofee malware family, alongside a broad set of associated tools such as ShadowPad, PlugX, Cobalt Strike, and others. The operation does not cite a concrete vulnerability (the

central CVE is listed as Data Insufficient). Victim details, including country and sector, are also recorded as insufficient.

Attack Chain and Priority Control

The observed chain begins with system checks and information discovery, proceeds to schedule tasks via cron and systemd services, then uses native API calls (T1106) to load malicious modules and perform process injection. Obfuscation, decryption, and masquerading techniques conceal the payload, which communicates over DNS, FTP, and web protocols while exfiltrating data over the C2 channel. The chokepoint technique is **T1106 Native API**, and the recommended control is: **Enable EDR API-telemetry; alert on unusual direct Native API use from non-system processes.**

Infrastructure and Corroboration

Third-party enrichment shows that the command-and-control infrastructure is hosted by providers including G-Core Labs S.A., Light Node Limited, UFO Hosting LLC, and Kaopu Cloud HK Limited. AbuseIPDB reports no high-confidence malicious indicators associated with the observed IPs. No additional malware families were corroborated by abuse.ch.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1014 Rootkit
- T1071.004 DNS
- T1573.001 Symmetric Cryptography
- T1497.001 System Checks
- T1053.003 Cron
- T1082 System Information Discovery
- T1106 Native API
- T1140 Deobfuscate/Decode Files or Information
- T1055 Process Injection
- T1070.006 Timestomp
- T1090 Proxy
- T1083 File and Directory Discovery
- T1036.004 Masquerade Task or Service
- T1041 Exfiltration Over C2 Channel
- T1071.002 File Transfer Protocols
- T1059.004 Unix Shell
- T1027 Obfuscated Files or Information
- T1071.001 Web Protocols
- T1543.002 Systemd Service

- T1105 Ingress Tool Transfer

Analytical Scores

- Priority technique (graph chokepoint): T1106 Native API (centrality 0.2658).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4543; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Rocke	0.4543
APT18	0.4454
Higaisa	0.4132
Tropic Trooper	0.3788
Darkhotel	0.3565

Enrichment Signal

- Highest AbuselPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	92[.]38[.]169[.]152	AbuselPDB 0% (US) · AS199524 G-Core Labs S.A.
IP	185[.]163[.]2[.]79	AbuselPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	45[.]67[.]230[.]185	AbuselPDB 0% (RU) · AS33993 UFO Hosting LLC
IP	180[.]149[.]44[.]115	AbuselPDB 0% (AZ) · AS202422 G-Core Labs S.A.
IP	185[.]163[.]2[.]34	AbuselPDB 0% (IN) · AS202422 G-Core Labs S.A.

Type	Indicator	Context
IP	38[.]54[.]110[.]44	AbuseIPDB 0% (US) · AS138915 Kaopu Cloud HK Limited
IP	130[.]94[.]91[.]165	AbuseIPDB 0% (NP) · AS154177 Light Node Limited
IP	103[.]215[.]216[.]117	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	89[.]44[.]198[.]107	AbuseIPDB 0% (DE) · AS202422 G-Core Labs S.A.
IP	103[.]215[.]216[.]181	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	185[.]163[.]2[.]100	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	103[.]215[.]216[.]61	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	185[.]163[.]2[.]81	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	146[.]71[.]85[.]33	AbuseIPDB 0% (US) · AS26042 FiberState LLC
IP	103[.]215[.]216[.]116	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	103[.]215[.]216[.]162	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	103[.]215[.]216[.]27	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	103[.]215[.]216[.]75	AbuseIPDB 0% (IN) · AS202422 G-Core Labs S.A.
IP	103[.]87[.]9[.]148	AbuseIPDB 0% (HK) · AS132883 Topway Global Limited
IP	130[.]94[.]91[.]53	AbuseIPDB 0% (NP) · AS154177 Light Node Limited
IP	154[.]205[.]137[.]88	AbuseIPDB 0% (HK) · AS154177 Light Node Limited
IP	180[.]149[.]44[.]110	
IP	180[.]149[.]44[.]43	
IP	2[.]56[.]166[.]139	
IP	2[.]56[.]166[.]84	
IP	38[.]54[.]71[.]107	
IP	38[.]54[.]71[.]56	
IP	45[.]80[.]208[.]232	
Domain	blog[.]exatrack[.]com	
Domain	blog-en[.]itochuci[.]co[.]jp	

Type	Indicator	Context
Domain	www[.]windefender[.]net	
Domain	windefender[.]net	
Domain	microsoftupdates[.]top	
Domain	amzaonaws[.]org	
Domain	microupdate[.]me	
Domain	microupdate[.]top	
Domain	windowsupdates[.]us	
Domain	awsclouds[.]awspull[.]com	
Domain	documentation[.]stormshield[.]eu	
Domain	update[.]miss-soft[.]com	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1106 Native API (execution)
- **Observed here:** T1106 Native API was the execution control point here; the pivot is drawn from APT41's own documented ATT&CK repertoire.
- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** documented in APT41's own ATT&CK repertoire, and disproportionately paired with Native API across tracked groups (lift 1.6, ~1.6x base rate). Their move, not a generic one.

With T1106 Native API blocked, APT41 could preserve the same objective by pivoting to T1047 Windows Management Instrumentation, a technique from APT41's documented repertoire. Defensive countermeasure: Monitor wmiprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

Also plausible (same tactic): T1574 Hijack Execution Flow (n=9, lift 2.1), T1203 Exploitation for Client Execution (n=7, lift 1.5)

Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**

- Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
- wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
- WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
 - Restrict WMI remote access; monitor permanent WMI subscriptions
 - Least-privilege; segment management protocols
- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command

